

5.2 Token Management

Control Type: Mandatory	Applies to architecture:	A1	A2	A3	A4	B
Control Definition Control Objective: Ensure the proper management, tracking, and use of connected and disconnected hardware authentication or personal and software tokens (when tokens are used). In-scope components: - connected and disconnected hardware authentication or personal tokens used for Swift operations or secure zone access - software tokens used as second authentication factor (when explicitly identified for their assignment and management in support of control 4.2) - PIN Entry Device (PED) used for HSM operations Risk Drivers: - authentication token theft - lack of traceability - HSM management misused						
Implementation Guidance Control Statement: Connected and disconnected hardware authentication or personal and software tokens are managed appropriately during their assignment, distribution, revocation, use, and storage. Control Context: The protection of connected and disconnected hardware authentication, personal tokens or software tokens is essential to safeguarding the related operator or system account. It also reinforces good security practice by providing an additional layer of protection from attackers. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives). - A controlled process is used for the assignment and distribution of connected and disconnected hardware, personal tokens or software tokens used for Swift operations (for example USB token, HSM token, smart card, (T)OTP- generator or application storing a cryptographic private key that runs on another device like operator's mobile phone). - Hardware and software token assignment, including those delegated to a provider, is reviewed at least annually (more frequently is recommended). - Personally assigned hardware or software tokens, including those delegated to a provider, are revoked when the individual no longer requires access and should be recalled (for possible disposal or reassignment as appropriate). - A record is maintained of assigned hardware token ownership. - Hardware token is supervised (it always remains under the control of its owner) or it is securely stored. As such, it does not stay plugged in a device unattended by the token owner. - When PED keys are used, the following security practices apply:						

- PED keys must be stored and only accessible by relevant staff (originals and copies should be stored in a safe with access tracking)
- Although the HSM PED keys are not personally assigned, usage should be controlled, tracked and monitored. In case a PIN is set on the PED keys and a person with access to these keys and PIN is leaving the company, the PIN codes should be changed
- The PED flows to the HSM must be secured as per the Alliance Security Guidance considering also the [CSP FAQ](#) (Knowledge Base article 5021823 related to control 5.2 remote PED keys) to properly establish and manage the connection.